

Cyber Threat Intelligence Report

07th of November 2026

TLP:CLEAR - May be shared publicly

Critical Rails Active Storage Flaw (CVE-2026-122006): Unauthenticated Server File Access

Risk Level

☐ CRITICAL

☑ HIGH

☐ MEDIUM

☐ LOW

Report ID

TW-CTI-2026-003

Vulnerability Overview

Vulnerability: CVE-2026-122006, CVSS 9.8 (Critical)

Affected: Rails Active Storage using ImageMagick, before 8.1.4.1 (Rails 8.1) and 8.0.5.2 (Rails 8.0)

Attack Vector: A crafted file upload; no login is required

Disclosed: 4 November 2026

Exploitation: None confirmed at the time of writing

Impact

Who is affected: Rails applications that use Active Storage with ImageMagick (not the default libvips processor) and accept uploads from untrusted users.

An unauthenticated attacker could use a crafted upload to read and write files on the server. Reading files such as secret_key_base and credentials could lead to code execution and takeover. Rated HIGH for affected apps: critical severity, no login needed and a patch available. No exploitation had been reported at the time of writing, which can change quickly.

ATTACKER OBJECTIVES AND ATTACK PATH

Assessed Attacker Objectives

- **Read secrets:** secret_key_base, database credentials and storage keys.
- **Write files:** for example, to plant a web shell on the server.
- **Expand access:** use the foothold to reach connected systems and data.

Possible Attack Path

- **Reconnaissance:** An attacker looks for public Rails applications that accept uploads and use ImageMagick for Active Storage.
- **Delivery:** The attacker uploads a crafted file that abuses ImageMagick features the system policy does not block.
- **Execution:** Active Storage analyzes the attachment as soon as it arrives, so the flaw can trigger without any image preview or transformation request.
- **Persistence and control:** The attacker could read secrets such as secret_key_base or write files, which could be used to plant a web shell or forge signed cookies.
- **Actions on objectives:** With that access the attacker could reach connected systems, steal data or run commands on the server.

TECHNICAL DETAILS

CVE-2026-122006 affects Active Storage when attachments are processed with ImageMagick. It was published on 4 November 2026 with a CVSS 3.1 score of 9.8 (network, low complexity, no privileges, no user interaction). The weakness is classed as an insecure default: ImageMagick can handle file formats and features that are unsafe for untrusted input unless a security policy blocks them.

Active Storage analyzes an attachment immediately when it is received, so the flaw can be triggered by the upload alone, without any request to transform or preview the image. A successful attack lets an unauthenticated user read and write files that the Rails process can access.

The Rails team fixed the flaw in 8.1.4.1 and 8.0.5.2, released on 4 November 2026 in a batch that fixed 21 issues. The fix guidance also calls for mini_magick 5.1 or newer and a hardened ImageMagick policy.xml. Where neither is possible at once, disabling ImageMagick variant processing and the video and preview analyzers is the stop-gap. Separately, security support for Rails 8.0 ends on 7 November 2026, so 8.0.5.2 is likely the last security release for that line. This is a different issue from the earlier libvips flaw, CVE-2026-66066.

AFFECTED VERSIONS AND INDICATORS

Affected

- Active Storage using ImageMagick for attachment processing
- Rails 8.1 before 8.1.4.1
- Rails 8.0 before 8.0.5.2

Fixed in

- Rails 8.1.4.1 and 8.0.5.2 (released 4 November 2026)
- mini_magick 5.1 or newer (recommended with the fix)

Quick checks

- Gemfile.lock: the Rails version, and whether mini_magick is present
- Whether Active Storage is configured to use ImageMagick (mini_magick) for image processing
- Upload and storage directories: unexpected new files
- Application logs: ImageMagick or shell processes started around upload events

CVEs

- CVE-2026-122006

Recommendations and References

Recommendations

- **Today:** Check exposure. Look in Gemfile.lock for your Rails version and confirm whether Active Storage uses ImageMagick. Apps on the default libvips processor are not affected by this CVE.
- **Today:** Upgrade to Rails 8.1.4.1 or 8.0.5.2 and to mini_magick 5.1 or newer. The same releases fix 20 other security issues.
- **If you cannot upgrade today:** Apply a restrictive ImageMagick policy.xml that blocks dangerous coders and delegates, or disable ImageMagick variant processing and the video and preview analyzers until you can patch.
- **This week:** If the app accepted public uploads while unpatched, review upload logs and storage for unexpected files, and rotate secret_key_base, database and storage credentials if you find signs of abuse.
- **This month:** Rails 8.0 reaches end of security support on 7 November 2026. Plan the move to 8.1.
- **Optional:** Some security vendors, including Socket, offer interim patches. Treat them as a stop-gap, not a replacement for the upgrade.

References

- https://app.opencve.io/cve/CVE-2026-122006
- https://www.linuxcompatible.org/story/rails-8141-and-8052-security-release-21-cves-packed-80-eol-in-days/
- https://socket.dev/blog/rails-active-storage-patch

STAY VIGILANT

Implement these recommendations to protect your organization from this threat.

For Support

Email: info@threatwire-intelligence.com

© 2026 Threat Wire. All Rights Reserved.